

SOFTWARE REQUIREMENTS SPECIFICATION

GPunch — Secure On-Site Presence Verification System

Course / Module	23MX21 - Software Engineering
Document Type	Software Requirements Specification (SRS)
Version	1.0
Date	May 2026
Institution	PSG College of Technology, Coimbatore - 641 004
Department	Computer Applications (MCA)
Prepared By	Kavin M · Shanmugappriya K
Faculty Guide	Dr. N. Ilayaraja, Associate Professor
Status	Final

TABLE OF CONTENTS

Section	Title	Page
1	Introduction	3
1.1	Purpose	3
1.2	Intended Audience	3
1.3	Project Scope	3
1.4	Definitions, Acronyms & Abbreviations	4
1.5	References	4
2	Overall Description	5
2.1	Product Perspective	5
2.2	Product Functions	5
2.3	User Classes and Characteristics	6
2.4	Operating Environment	6
2.5	Design and Implementation Constraints	6
2.6	Assumptions and Dependencies	7
3	System Features / Functional Requirements	7
4	External Interface Requirements	14
4.1	User Interfaces	14
4.2	Hardware Interfaces	14
4.3	Software Interfaces	14
4.4	Communication Interfaces	15
5	Non-Functional Requirements	15
6	Other Requirements	16
7	Appendix	17

1. INTRODUCTION

1.1 Purpose

This Software Requirements Specification (SRS) defines the complete functional and non-functional requirements for **GPunch**, a secure, passwordless on-site pres-

ence verification system. The purpose of this document is to provide a clear and unambiguous basis for the design, development, testing, and maintenance of the GPunch system.

The system eliminates traditional attendance fraud (buddy punching, proxy attendance, GPS spoofing) by combining three independently verified factors:

1. **Institutional email OTP** — confirms identity
2. **Android device binding (ANDROID_ID)** — confirms device ownership
3. **Server-side GPS geofencing (Haversine)** — confirms physical presence

No passwords, maps, selfies, or biometrics are required.

1.2 Intended Audience

This document is intended for the following readers:

Reader	Purpose
Software Developers	Implementation guidance for backend and Android client
Faculty Guide & Evaluators	Academic review and project assessment
System Administrators	Deployment, configuration, and maintenance
QA / Testers	Basis for writing and executing test cases
End Users (Future Reference)	Understanding system behaviour and limitations

1.3 Project Scope

GPunch is a two-component system:

- **Backend REST API** (Node.js 18 + Express + MongoDB Atlas): manages user accounts, OTP authentication, geofence configuration, attendance records, and security audit logs.
- **Android Mobile Client** (Kotlin, API 26+): provides the registration, authentication, GPS-based clock-in/clock-out, and background geofence monitoring interface.

In Scope

- Domain-restricted self-registration using institutional email OTP
- Single-device binding per user account (ANDROID_ID)
- GPS geofence clock-in/clock-out with server-side Haversine distance validation
- Automatic clock-out when the device exits the geofence boundary
- Mock/fake GPS detection and denial
- Offline clock-out payload queueing with automatic retry on network restoration
- Admin portal: geofence setup, domain management, device reset, CSV export, audit logs

Out of Scope

- Web-based employee self-service dashboard
- Biometric authentication (fingerprint, face recognition)
- IoT beacon-based proximity attendance
- Integration with HR management or payroll systems
- Multi-campus or multi-geofence support (single-site only in v1.0)

1.4 Definitions, Acronyms, and Abbreviations

Term	Definition
OTP	One-Time Password — 6-digit numeric code sent to registered email
JWT	JSON Web Token — stateless, signed token used for API session management
GPS	Global Positioning System
Geofence	A virtual geographic boundary defined by a centre coordinate (lat/lng) and a radius in metres
Haversine	Mathematical formula computing the great-circle distance between two GPS coordinates
ANDROID_ID	64-bit hexadecimal string uniquely identifying a device per app install and signing key
API	Application Programming Interface
REST	Representational State Transfer — architectural style for networked APIs
SRS	Software Requirements Specification
MVVM	Model-View-ViewModel — Android architectural pattern
FR	Functional Requirement
NFR	Non-Functional Requirement
TC	Test Case
MCA	Master of Computer Applications
ODM	Object Document Mapper
FLP	Fused Location Provider (Google Play Services)

1.5 References

1. IEEE Std 830-1998: *IEEE Recommended Practice for Software Requirements Specifications*
2. Android Developers — [Foreground Services](#)
3. Android Developers — [WorkManager](#)
4. Express.js Documentation — <https://expressjs.com>
5. Mongoose ODM Documentation — <https://mongoosejs.com>
6. RFC 7519 — *JSON Web Token (JWT)*
7. PSG College of Technology, MCA Department — Project Guidelines 2025–2026

2. OVERALL DESCRIPTION

2.1 Product Perspective

GPunch is a standalone system that operates as an independent attendance verification layer within any institution that uses Android devices. It does not replace existing HR systems but generates tamper-proof, audit-ready attendance records that can be exported and imported into those systems.

The system follows a client-server architecture:



2.2 Product Functions

The table below summarises the primary functions of the system:

#	Function	Actor
F-01	Domain-restricted self-registration with OTP	Employee
F-02	OTP verification with permanent device binding	Employee
F-03	Passwordless login via institutional email OTP	Employee
F-04	GPS settings check and high-accuracy location fetching	Employee
F-05	Server-side geofence clock-in with Haversine validation	Employee
F-06	Manual clock-out	Employee
F-07	Mock / fake GPS detection and denial	System
F-08	Background geofence monitoring with persistent notification	System
F-09	Automatic clock-out on geofence boundary breach	System
F-10	Offline clock-out queueing via WorkManager	System

#	Function	Actor
F-11	Admin: Configure geofence (lat/lng/radius/domain)	Admin
F-12	Admin: Reset / unlink user device binding	Admin
F-13	Admin: View security audit logs (filterable, paginated)	Admin
F-14	Admin: Export attendance data as CSV	Admin
F-15	Admin: List and manage registered users	Admin

2.3 User Classes and Characteristics

Employee (Regular User) - MCA student or institution staff member - Holds a valid institutional email (e.g., @psgtech.ac.in) - Owns an Android smartphone (Android 8.0 / API 26 or higher) - Non-technical; interacts only through the Android app - Requires no password knowledge

System Administrator - Technical staff responsible for system setup and monitoring - Accesses the system via REST API (Postman, curl, or a future web portal) - Configures geofence, manages domains and devices, reviews audit logs, exports data - Holds an elevated JWT role (admin)

System (Automated Actor) - Background processes acting on behalf of logged-in users - GeofenceMonitorService — detects boundary exit, triggers auto clock-out - PendingClockOutWorker — retries clock-out payload when connectivity is restored

2.4 Operating Environment

Backend

Component	Specification
Runtime	Node.js $\geq$ 18.0.0
Framework	Express.js ^4.18
Database	MongoDB Atlas (M0 free tier or higher)
Deployment	Any HTTPS-capable Node.js host (Render, Railway, VPS)
Email / SMTP	Gmail with App Password (or any SMTP provider)

Android Client

Component	Specification
Minimum SDK	API 26 (Android 8.0 Oreo)
Target SDK	API 34 (Android 14)
Language	Kotlin 1.9.23
Architecture	ARM / ARM64 / x86_64

Component	Specification
Required Permissions	FINE_LOCATION, COARSE_LOCATION, BACKGROUND_LOCATION, FOREGROUND_SERVICE, FOREGROUND_SERVICE_LOCATION, POST_NOTIFICATIONS, RECEIVE_BOOT_COMPLETED, INTERNET, ACCESS_NETWORK_STATE

2.5 Design and Implementation Constraints

Constraint	Rationale
No passwords	Eliminates credential sharing; OTP-only authentication
No mapping SDK	Only coordinate-based geofencing is needed; reduces APK size and dependencies
No selfies or biometrics	Privacy preservation; device binding provides equivalent identity assurance
Single active geofence	v1.0 targets single-campus deployments
Physical device recommended	Emulators produce unreliable GPS coordinates
HTTPS enforced	All API calls require TLS; enforced by OkHttp on Android
Rate limiting	Auth endpoints: 20 req/15 min; global: 100 req/15 min
Input validation	All request bodies validated with express-validator
NoSQL injection prevention	All Mongoose queries use explicit typed parameters

2.6 Assumptions and Dependencies

1. Users have uninterrupted access to their institutional email for OTP receipt.
2. The Android device has functional GPS hardware, and the user grants all required location permissions.
3. The system administrator configures the geofence before employees attempt to clock in.
4. Network connectivity is available for clock-in; clock-out operates offline with automatic retry.
5. The institution controls its email domain exclusively (no public sub-domain reuse).
6. Google Play Services is available on target Android devices (required for FLP and WorkManager).

3. SYSTEM FEATURES / FUNCTIONAL REQUIREMENTS

FR-01: Domain-Restricted Self-Registration

Description The system allows employees to self-register using only an institutional email address. Registrations from non-institutional domains are automatically rejected without admin intervention.

Stimulus / Response Sequences

Step	Actor	Action
1	Employee	Opens app, navigates to Register, enters name + institutional email
2	System	Calls POST /api/auth/register with { name, email, androidId }
3	Backend	Loads GeofenceConfig.allowedDomain from database
4	Backend	Extracts domain from email (email.split('@')[1]), compares against allowed domain
5a	Backend (match)	Generates 6-digit OTP, stores hashed equivalent with 10-min expiry, sends OTP email
5b	Backend (mismatch)	Returns HTTP 403, logs INVALID_DOMAIN audit event

Functional Requirements

ID	Requirement
FR-01.1	The backend shall compare the email domain against GeofenceConfig.allowedDomain on every registration request.
FR-01.2	If the domain does not match, the system shall return HTTP 403 with message "Email domain is not allowed."
FR-01.3	Every rejected registration attempt shall create an INVALID_DOMAIN entry in the AuditLog collection.
FR-01.4	If the domain matches, a 6-digit numeric OTP shall be generated, stored with a 10-minute expiry, and sent to the user's email.

ID	Requirement
FR-01.5	Duplicate registrations from the same email shall return HTTP 409.

Priority: High | **Test Cases:** TC-01, TC-02

FR-02: OTP Verification and Device Binding

Description Upon entering the received OTP, the system verifies it and permanently binds the user's ANDROID_ID to their account, preventing use from any other device.

Stimulus / Response Sequences

Step	Actor	Action
1	Employee	Enters 6-digit OTP in OtpActivity
2	System	Calls POST /api/auth/verify-otp with { email, otp, androidId }
3	Backend	Looks up user by email, compares OTP as string (type-safe), checks expiry
4a	Backend (valid)	Sets isVerified = true, stores androidId, issues JWT
4b	Backend (invalid)	Returns HTTP 400, logs OTP_FAILED audit event

Functional Requirements

ID	Requirement
FR-02.1	OTP comparison shall be performed as a strict string equality check to prevent type coercion attacks.
FR-02.2	If the OTP has expired (<code>otpExpiresAt < Date.now()</code>), HTTP 400 shall be returned and OTP_FAILED shall be logged.
FR-02.3	On successful verification, <code>androidId</code> shall be permanently stored against the user record.
FR-02.4	On successful verification, a signed JWT (HS256, 7-day expiry) shall be issued and returned.

ID	Requirement
FR-02.5	The OTP value shall never be returned in any API response.

Priority: High | **Test Case:** TC-03

FR-03: Device Binding Enforcement

Description A verified user may only log in from the device they originally registered with. Attempting login from a different device is rejected and logged as a security event.

Stimulus / Response Sequences

Step	Actor	Action
1	Employee	Enters email on Login screen (from a different device)
2	System	Calls POST /api/auth/login with { email, androidId }
3	Backend	Compares req.body.androidId against user.androidId using strict equality
4a	Backend (match)	Sends OTP to registered email
4b	Backend (mismatch)	Returns HTTP 403, logs UNAUTHORIZED_DEVICE

Functional Requirements

ID	Requirement
FR-03.1	The login endpoint shall compare the submitted androidId against the stored device binding.
FR-03.2	A mismatch shall return HTTP 403 with message "Device not recognised."
FR-03.3	Every failed device check shall create an UNAUTHORIZED_DEVICE entry in AuditLog.
FR-03.4	An admin may reset a device binding to allow re-binding (see FR-10).

Priority: High | **Test Case:** TC-04

FR-04: GPS Settings Check and Location Fetching

Description Before attempting clock-in, the Android app verifies that high-accuracy GPS is enabled. If GPS is off, a native system dialog is presented to the user without requiring them to navigate to Settings manually.

Stimulus / Response Sequences

Step	Actor	Action
1	Employee	Taps "Clock In" on Dashboard
2	App	Builds LocationSettingsRequest with PRIORITY_HIGH_ACCURACY
3	App	Calls LocationServices.getSettingsClient().checkLocationSettings()
4a	App (satisfied)	Calls getCurrentLocation() and proceeds to clock-in
4b	App (not satisfied)	Catches ResolvableApiException, launches system settings dialog via IntentSenderRequest

Functional Requirements

ID	Requirement
FR-04.1	The app shall check GPS settings before every clock-in attempt.
FR-04.2	If GPS is disabled, the system Android settings dialog shall be displayed in-app (no manual navigation required).
FR-04.3	Clock-in shall only proceed after GPS coordinates are successfully obtained.

Priority: High | **Test Case:** TC-05

FR-05: Geofence-Based Clock-In

Description Clock-in is only permitted when the user is physically within the configured geofence radius. The server independently re-validates coordinates to prevent client-side manipulation.

Stimulus / Response Sequences

Step	Actor	Action
1	Employee	Taps Clock In; app obtains GPS coordinates
2	App	Checks location.isMock; if mock, denies immediately (see FR-06)
3	App	Calls POST /api/punch/in with { latitude, longitude, androidId }
4	Backend	Loads GeofenceConfig; computes haversineDistance(config, user)
5a	Backend (inside)	Creates AttendanceRecord with clockInTime, returns HTTP 201
5b	Backend (outside)	Returns HTTP 403 with distance and allowedRadius; logs OUT_OF_BOUNDS

Functional Requirements

ID	Requirement
FR-05.1	The server shall compute Haversine distance independently of client-provided assertions.
FR-05.2	If distance > config.allowedRadius, HTTP 403 shall be returned with the actual distance in the response body.
FR-05.3	A successful clock-in shall create an AttendanceRecord with clockInTime, clockInLat, clockInLng, userId, and androidId.
FR-05.4	The app shall display the computed distance to the user on the Dashboard.

Priority: High | **Test Cases:** TC-06, TC-07

FR-06: Mock / Fake GPS Detection

Description The Android client detects whether the GPS location is being spoofed by a third-party mock location application. If spoofing is detected, clock-in is denied and the event is logged.

Functional Requirements

ID	Requirement
FR-06.1	The app shall call <code>location.isMock</code> (API 18+, reliable from API 31+) on every location fix.
FR-06.2	For devices below API 31, the app shall additionally check <code>Settings.Secure.ALLOW MOCK LOCATION</code> .
FR-06.3	If either check returns true, clock-in shall be denied with a user-visible toast message.
FR-06.4	The app shall report a <code>MOCK_LOCATION</code> event to <code>POST /api/audit</code> with the detected location data.

Priority: High | **Test Case:** TC-08

FR-07: Background Location Monitoring with Persistent Notification

Description After a successful clock-in, a foreground service starts and continuously monitors the user's GPS position. A persistent Android notification is displayed for the duration of the session.

Functional Requirements

ID	Requirement
FR-07.1	<code>GeofenceMonitorService</code> shall be started as an Android Foreground Service immediately after a successful clock-in.
FR-07.2	A persistent notification shall appear in the Android notification tray while the service is running.
FR-07.3	The service shall use <code>FusedLocationProviderClient.requestLocationUpdates()</code> with adaptive intervals: 15 seconds when moving (≥ 5 m displacement), 60 seconds when stationary.
FR-07.4	The foreground service shall survive app background/kill and device screen-off events.

Priority: High | **Test Case:** TC-09

FR-08: Automatic Clock-Out on Geofence Breach

Description When the background monitoring service detects that the user has left the geofence, it automatically calls the clock-out API and notifies the user.

Functional Requirements

ID	Requirement
FR-08.1	When the service detects <code>haversineDistance > fenceRadius</code> , it shall call <code>POST /api/punch/out</code> with <code>autoClockOut: true</code> .
FR-08.2	<code>SessionManager.setIsClockedin(false)</code> shall be updated immediately to reflect the change in app state.
FR-08.3	A push notification shall be displayed: "You have left the work zone. Attendance has been recorded."
FR-08.4	The foreground service shall stop after auto clock-out is recorded.

Priority: High | **Test Case:** TC-10

FR-09: Admin — Geofence and Domain Configuration

Description The system administrator configures the geofence centre coordinates, radius, and allowed email domain. Changes take effect immediately for all subsequent clock-in attempts.

Functional Requirements

ID	Requirement
FR-09.1	Endpoint <code>POST /api/admin/geofence</code> (admin JWT required) shall accept { <code>latitude</code> , <code>longitude</code> , <code>allowedRadius</code> , <code>allowedDomain</code> }.
FR-09.2	The upsert operation shall ensure only one <code>GeofenceConfig</code> document exists at any time.
FR-09.3	All subsequent <code>POST /api/punch/in</code> requests shall fetch the latest <code>GeofenceConfig</code> from the database.

Priority: High | **Test Case:** TC-11

FR-10: Admin — Device Unlinking (Reset)

Description The administrator can clear a user's device binding, allowing them to re-bind with a new device on their next OTP verification.

Functional Requirements

ID	Requirement
FR-10.1	Endpoint POST /api/admin/reset-device/:userId (admin JWT required) shall set user.androidId = null.
FR-10.2	After the reset, the user may complete OTP verification from any device, which will bind that new device.

Priority: High | **Test Case:** TC-12

FR-11: Admin — Security Audit Log Viewing

Description The administrator can view a paginated, filterable list of all security events in the system to monitor for proxy/buddy punching attempts.

Functional Requirements

ID	Requirement
FR-11.1	Endpoint GET /api/admin/audit-logs shall support query parameters: eventType, page, limit.
FR-11.2	The eventType filter shall validate against a whitelist to prevent injection.
FR-11.3	Each log entry shall include: userId, email, androidId, eventType, timestamp, ipAddress, metadata.

Logged Event Types

Event Type	Trigger
INVALID_DOMAIN	Registration with non-institutional email
OTP_FAILED	Incorrect or expired OTP submitted
UNAUTHORIZED_DEVICE	Login attempted from unbound device
MOCK_LOCATION	Fake GPS app detected on client
OUT_OF_BOUNDS	Clock-in attempted outside geofence
SUSPICIOUS_ACTIVITY	Other anomalies reported by the client

Priority: High | **Test Case:** TC-13

FR-12: Offline Clock-Out Queueing

Description If the automatic clock-out API call fails due to network unavailability (e.g., Airplane Mode), the payload is persisted locally and retried automatically when connectivity is restored.

Functional Requirements

ID	Requirement
FR-12.1	If POST /api/punch/out throws an IOException (or any network exception), a PendingClockOutWorker shall be enqueued via WorkManager.
FR-12.2	The WorkManager job shall have a CONNECTED network constraint, ensuring it only executes when internet is available.
FR-12.3	SessionManager.setIsClockedin(false) shall be set optimistically on the client before the retry.
FR-12.4	The WorkManager payload (JWT token, coordinates, androidId) shall persist across app restarts and device reboots.

Priority: Medium | **Test Case:** TC-14

FR-13: Admin — CSV Attendance Export

Description The administrator can download a complete attendance record report in CSV format for all users.

Functional Requirements

ID	Requirement
FR-13.1	Endpoint GET /api/admin/export-csv (admin JWT required) shall return a CSV file download.
FR-13.2	CSV columns shall include: Name, Email, Clock-In Time, Clock-Out Time, Duration (minutes), Auto Clock-Out, Android ID.

Priority: Medium

4. EXTERNAL INTERFACE REQUIREMENTS

4.1 User Interfaces

Android Application Screens

Screen	Key UI Elements	Description
Splash	Logo, progress indicator	Auto-redirects to Dashboard (if logged in) or Login
Login	Email input, OTP button	Passwordless login via institutional email
Register	Name + email inputs, OTP button	New account registration with domain check
OTP Verification	6-digit input, countdown timer, Resend	OTP entry with 60-second resend throttle
Dashboard	Clock-In/Out button, location info, status badge, history, logout	Main user interface

Navigation Flow

Splash --> Login --> OTP --> Dashboard
--> Register --> OTP --> Dashboard
Dashboard --> (on clock-in) --> Background Service active

4.2 Hardware Interfaces

Hardware	Requirement
GPS Receiver	Required for location acquisition; high-accuracy mode preferred
Network Interface	Wi-Fi or cellular data for API communication
Notification System	Android notification tray for persistent session notification
Storage	SharedPreferences for session token and state persistence

4.3 Software Interfaces

Interface	Technology	Purpose
MongoDB Atlas	Mongoose ODM v8.3	Persistent data storage for all collections
Gmail SMTP	Nodemailer v8.0	OTP email delivery
Fused Location Provider	Google Play Services 21.3.0	Accurate GPS coordinate acquisition
WorkManager	AndroidX WorkManager 2.9.0	Offline job scheduling and persistence

Interface	Technology	Purpose
Retrofit + OkHttp	Retrofit 2.11 / OkHttp 4.12	Android HTTP client with JWT interceptor
express-validator	v7.0	Server-side request body validation
helmet.js	v7.1	HTTP header security hardening
express-rate-limit	v7.2	Request rate limiting per IP

4.4 Communication Interfaces

Protocol	Usage
HTTPS (TLS 1.2+)	All client-server API communication
JSON	Request and response data format (Content-Type: application/json)
Bearer JWT	Authentication header (Authorization: Bearer <token>)
SMTP (port 587, STARTTLS)	OTP email delivery via Gmail

5. NON-FUNCTIONAL REQUIREMENTS

NFR-01: Security

ID	Requirement
NFR-01.1	All API endpoints except /api/auth/* and /health shall require a valid JWT.
NFR-01.2	Admin routes shall additionally require role: "admin" in the JWT payload.
NFR-01.3	OTP values shall never appear in API responses, logs, or database query results (stripped by Mongoose toJSON transform).
NFR-01.4	All Mongoose queries shall use explicit type casting to prevent NoSQL operator injection.
NFR-01.5	eventType filter query parameters shall be validated against a whitelist.
NFR-01.6	All HTTP response headers shall be hardened using helmet.js.
NFR-01.7	Request body size shall be capped at 10 KB to prevent payload flooding attacks.
NFR-01.8	HTTPS shall be enforced on all production deployments.

NFR-02: Performance

ID	Requirement
NFR-02.1	Clock-in API response time shall be ≤ 2 seconds under normal network conditions.
NFR-02.2	The app shall obtain a GPS fix within 10 seconds of the Dashboard opening.
NFR-02.3	Background service battery impact shall be minimised using adaptive GPS polling (15 s active / 60 s stationary).

NFR-03: Reliability

ID	Requirement
NFR-03.1	Offline clock-out payloads shall not be lost; WorkManager persistence survives both app restarts and device reboots.
NFR-03.2	BootReceiver shall restore the foreground service state after device reboot if the user was clocked in at shutdown.
NFR-03.3	Backend deployment on Render/Railway shall provide $\geq 99\%$ uptime for normal workday hours.

NFR-04: Usability

ID	Requirement
NFR-04.1	Registration shall require no passwords — only name, institutional email, and OTP.
NFR-04.2	The OTP resend timer (60 seconds) shall prevent abuse while allowing genuine resends.
NFR-04.3	All error messages shall be human-readable; no technical stack traces shall be exposed to the user.
NFR-04.4	The persistent notification shall provide one-tap navigation back to the Dashboard.

NFR-05: Scalability

ID	Requirement
NFR-05.1	MongoDB Atlas M0 (free tier) shall support ≥ 500 concurrent registered users for a single-campus deployment. Global rate limiting (100 req / 15 min per IP) shall protect server resources.
NFR-05.2	

NFR-06: Maintainability

ID	Requirement
NFR-06.1	Backend code shall follow MVC separation: models, routes (controllers), middleware, utilities. Android code shall follow MVVM: Activities (Views) $\rightarrow$ ViewModels $\rightarrow$ Repositories (API).
NFR-06.2	
NFR-06.3	All secrets and configuration values shall be externalised to environment variables; no hardcoded secrets in source code.
NFR-06.4	Backend unit tests shall achieve $\geq 80\%$ coverage for utility functions and critical auth paths.

6. OTHER REQUIREMENTS

6.1 Legal and Compliance Requirements

- Location data (GPS coordinates) shall be stored only for legitimate attendance tracking purposes.
- No biometric data is collected or stored.
- The ANDROID_ID is a device-level pseudonymous identifier; it does not directly identify a natural person.
- Institutional administrators are responsible for ensuring that the system is deployed in accordance with applicable data protection regulations (e.g., DPDP Act 2023 for India).

6.2 Test Case Traceability Matrix

Test ID	Requirement	Input / Action	Expected Output	FR Ref	Result
TC-01	Domain Restriction - Reject	Register with user@gmail.com	HTTP 403; IN-VALID_DOMAIN logged	FR-01	☐ Pass

Test ID	Requirement	Input / Action	Expected Output	FR Ref	Result
TC-02	Domain Restriction	Register with user@psgtech.com	HTTP 200; OTP email sent	FR-01	☐ Pass
TC-03	- Accept OTP Verification Failure	Submit wrong 6-digit OTP	HTTP 400; OTP_FAILED	FR-02	☐ Pass
TC-04	Device Binding Enforcement	Login from Device 2 (bound to Device 1)	HTTP 403; UNAUTH0-RIZED_DEVICE	FR-03	☐ Pass
TC-05	GPS Settings Check	Tap Clock-In with GPS disabled	System location settings dialog displayed	FR-04	☐ Pass
TC-06	Geofence Inside	Clock-in at 20 m from fence centre	HTTP 201; foreground service starts	FR-05	☐ Pass
TC-07	Geofence Outside	Clock-in at 200 m from fence centre	HTTP 403; distance returned	FR-05	☐ Pass
TC-08	Mock Location Detection	Enable Fake GPS app, attempt clock-in	Denied; toast shown; MOCK_LOCATION logged	FR-06	☐ Pass
TC-09	Background Tracking	Minimise app after Clock-In	Persistent notification visible in tray	FR-07	☐ Pass
TC-10	Auto Clock-Out	Move 100+ m from campus boundary	Clock-out API called; user notified	FR-08	☐ Pass
TC-11	Admin Geofence Config	Change radius 50 m → 10 m	Users at 20 m rejected on next clock-in	FR-09	☐ Pass
TC-12	Admin Device Reset	Admin resets Device binding for User A	User A can bind new device on next login	FR-10	☐ Pass

Test ID	Requirement	Input / Action	Expected Output	FR Ref	Result
TC-13	Audit Log Visibility	Admin views security dashboard	TC-01, TC-03, TC-04, TC-08 events visible	FR-11	☑ Pass
TC-14	Offline Clock-Out Queue	Auto clock-out in Airplane Mode	Payload queued; sent on network restoration	FR-12	☑ Pass

6.3 Data Model Summary

Collection	Key Fields	Purpose
users	name, email, role, androidId, otp, otpExpiresAt, isVerified	User accounts and device binding
attendancerecords	userId, email, clockInTime, clockOutTime, durationMinutes, autoClockOut	Attendance history
geofenceconfigs	latitude, longitude, allowedRadius, allowedDomain	Active geofence parameters
auditlogs	userId, email, eventType, ipAddress, latitude, longitude, metadata	Security event trail

6.4 API Endpoint Summary

Method	Endpoint	Auth	Description
POST	/api/auth/register	None	Register new user (domain check + OTP)
POST	/api/auth/verify-otp	None	Verify OTP + bind device + issue JWT
POST	/api/auth/login	None	Passwordless login (sends OTP)
POST	/api/auth/resend-otp	None	Resend OTP
POST	/api/punch/in	JWT	Clock in (geofence + mock check)

Method	Endpoint	Auth	Description
POST	/api/punch/out	JWT	Clock out (manual or auto)
GET	/api/punch/status	JWT	Get current clock-in status
GET	/api/punch/history	JWT	Get attendance history (paginated)
POST	/api/admin/seed	None*	Bootstrap first admin account
POST	/api/admin/geofence	JWT + Admin	Set geofence configuration
GET	/api/admin/geofence	JWT + Admin	Get geofence configuration
POST	/api/admin/reset-device/:id	JWT + Admin	Clear device binding
GET	/api/admin/users	JWT + Admin	List registered users
GET	/api/admin/audit-logs	JWT + Admin	View security audit logs
GET	/api/admin/export-csv	JWT + Admin	Download attendance CSV
POST	/api/audit	JWT	Report client-side security event

*Seed endpoint requires ADMIN_SEED_SECRET in request body.

7. APPENDIX

A. Haversine Distance Formula

The server computes the great-circle distance between two GPS coordinates using the Haversine formula:

ϕ_1, ϕ_2 = latitude values in radians
 λ_1, λ_2 = longitude values in radians
 R = 6,371,000 m (mean Earth radius)

$a = \sin^2((\phi_2 - \phi_1)/2) + \cos(\phi_1) \times \cos(\phi_2) \times \sin^2((\lambda_2 - \lambda_1)/2)$
 $c = 2 \times \text{atan2}(\sqrt{a}, \sqrt{1 - a})$
 $d = R \times c$ (distance in metres)

B. Environment Variables Reference

Variable	Required	Default	Description
PORT	No	3000	Express server port

Variable	Required	Default	Description
NODE_ENV	No	development	development or production
MONGODB_URI	Yes	—	MongoDB Atlas connection string
JWT_SECRET	Yes	—	HMAC-SHA256 signing key (≥ 32 chars)
JWT_EXPIRES_IN	No	7d	Token validity period
SMTP_HOST	Yes	—	SMTP server hostname
SMTP_PORT	No	587	SMTP server port
SMTP_USER	Yes	—	SMTP sender email address
SMTP_PASS	Yes	—	Gmail App Password
OTP_FROM	No	GPunch	Sender display name
OTP_EXPIRY_MINUTES	No	10	OTP validity in minutes
ADMIN_SEED_SECRET	Yes	—	One-time secret for seeding the first admin

C. Technology Stack

Layer	Technology	Version
Backend Runtime	Node.js	$\geq 18.0.0$
Backend Framework	Express.js	$\wedge 4.18$
Database ODM	Mongoose	$\wedge 8.3$
Authentication	jsonwebtoken	$\wedge 9.0$
Email	Nodemailer	$\wedge 8.0$
Input Validation	express-validator	$\wedge 7.0$
Security Headers	helmet	$\wedge 7.1$
Rate Limiting	express-rate-limit	$\wedge 7.2$
Database	MongoDB Atlas	M0+
Android Language	Kotlin	1.9.23
Android Min SDK	API 26 (Android 8.0 Oreo)	—
HTTP Client	Retrofit + OkHttp	2.11 / 4.12
Location Services	Google Play Services FLP	21.3.0
Background Jobs	AndroidX WorkManager	2.9.0
Architecture Pattern	MVVM + LiveData + Coroutines	—
Backend Testing	Jest + Supertest	$\wedge 29.7$ / $\wedge 7.0$

D. Revision History

Version	Date	Author	Change Description
0.1	April 2026	Kavin M	Initial draft — scope and FR outline
0.9	April 2026	Shanmugappriya K	Added NFRs, data models, API specification
1.0	May 2026	Kavin M, Shanmugappriya K	Final version — all 14 test cases verified and documented

Document ends — GPunch SRS v1.0 (23MX21 Template)